Rencana Eksekusi Hardening — Backend KABITA (Ubuntu + ThingsBoard)

Target: `192.168.4.5` (Ubuntu Server 26.04.1 LTS, ThingsBoard CE, PostgreSQL)

Acuan kontrol: `docs/blueteam/hardening_checklist.md` (10 kontrol: A-1…A-4, B-1…B-3, C-1…C-3)

Status saat ini: 0 kontrol `Selesai`, 3 `Sebagian` — dan bukti itu direkam pada stack **sementara** (nginx/MariaDB/Mosquitto), jadi harus direkam ulang pada ThingsBoard.

---

0. Prasyarat sebelum menyentuh hardening

#	Prasyarat	Perintah / cara	Kenapa wajib
1	ThingsBoard hidup dan menjawab	`curl -s -o /dev/null -w '%{http_code}' http://127.0.0.1:8080/login` → `200`	semua bukti "after" harus pada stack final
2	Snapshot bersih	`VBoxManage snapshot ... take "21-thingsboard-baseline"`	rollback bila lockout
3	Akses konsol VM tersedia	jendela VirtualBox, login `iotadmin`	satu-satunya jalan keluar bila SSH mati
4	SSH key untuk `iotadmin` sudah dibuat & diuji	`ssh-keygen -t ed25519`, `ssh-copy-id -p 2222 iotadmin@127.0.0.1`	A-2 mematikan password → tanpa key = terkunci
5	Baseline baru terekam	`sudo tcpdump -i enp0s3 -w /tmp/tb_base.pcap -c 800` sambil akses dashboard + kirim telemetri	pembanding deteksi; angka lama tidak berlaku
6	Catat IP sumber yang dipakai sendiri	host NAT = `10.0.3.2`, Kali = `192.168.4.100`	mencegah fail2ban/ufw mengunci diri sendiri

---

1. Aturan urutan — ini yang paling sering salah

Hardening **tidak boleh** semua dijalankan sebelum serangan, karena bukti `before` pada `purple-team-log.md` menjadi palsu (serangan tidak akan pernah berhasil). Bagi jadi dua tahap:

Tahap	Kontrol	Alasan
Tahap 1 — boleh sekarang (sebelum serangan)	A-1, A-3, A-4, B-1, B-2, B-3 (bagian patch), C-1, C-3	tidak menutup celah yang dipakai RT-02/RT-03/RT-04, jadi serangan baseline tetap bisa berhasil
Tahap 2 — setelah serangan baseline berhasil	B-3 (hapus akun default ThingsBoard), A-2 (key-only), C-2 (rotasi token + validasi + TLS)	inilah kontrol penutup; kalau dijalankan lebih dulu, RT-02/03/04 tidak punya `before`

Urutan per skenario di Fase 2: **serang (rekam) → deteksi → analisis → terapkan kontrol → uji ulang (rekam)**.

---

2. Kontrol satu per satu

A-1 · Nonaktifkan login `root` via SSH *(Tahap 1)*

```
sudo cp /etc/ssh/sshd_config /etc/ssh/sshd_config.bak
sudo sed -i 's/^#\?PermitRootLogin.*/PermitRootLogin no/' /etc/ssh/sshd_config
sudo sshd -t && sudo systemctl reload ssh
```

- **before:** `ssh root@192.168.4.5` → prompt password muncul / berhasil

- **after:** `ssh root@192.168.4.5` → `Permission denied (publickey,password)`
- **bukti:** `A1_before_root_prompt.txt`, `A1_after_root_denied.txt`
- **jebakan:** Ubuntu default `prohibit-password`; pastikan hasil `sshd -T | grep permitrootlogin` = `no`.

A-2 · SSH key-only (matikan password) *(Tahap 2 — setelah RT-02)*

```
sudo sed -i 's/^#\?PasswordAuthentication.*/PasswordAuthentication no/' /etc/ssh/sshd_config
sudo sed -i 's/^#\?KbdInteractiveAuthentication.*/KbdInteractiveAuthentication no/' /etc/ssh/sshd_config
sudo sshd -t && sudo systemctl reload ssh
```

- **before:** `sshpass -p '123' ssh -p 2222 iotadmin@127.0.0.1 whoami` → `iotadmin`
- **after:** perintah sama → `Permission denied`; `ssh -i ~/.ssh/id_ed25519 ...` → tetap masuk
- **bukti:** `A2_before_password_login_ok.png`, `A2_after_password_denied.txt`, `A2_after_key_login_ok.txt`
- **jebakan: uji key login di sesi kedua sebelum menutup sesi pertama.** Ini penyebab lockout nomor satu.

A-3 · Pindahkan SSH 22 → 2222 *(Tahap 1)*

```
sudo sed -i 's/^#\?Port .*/Port 2222/' /etc/ssh/sshd_config
sudo ufw allow 2222/tcp && sudo ufw delete allow 22/tcp
sudo systemctl restart ssh
```

- **before:** `ss -tlnp | grep :22`
- **after:** `ss -tlnp | grep :2222`; `nmap -p22,2222 192.168.4.5` → 22 `closed`, 2222 `open`
- **bukti:** `A3_before_ss_22.txt`, `A3_after_ss_2222.txt`, `A3_after_nmap.png`
- **jebakan:** buka 2222 di firewall **sebelum** restart sshd; port-forward VirtualBox `verify-ssh` juga harus diarahkan ke 2222.

A-4 · fail2ban untuk SSH *(Tahap 1)*

```
sudo apt install -y fail2ban
sudo tee /etc/fail2ban/jail.d/pbl.local >/dev/null <<'EOF'
[DEFAULT]
bantime = 900
findtime = 300
maxretry = 5
ignoreip = 127.0.0.1/8 10.0.3.2 192.168.4.200
[sshd]
enabled = true
port = 2222
EOF
sudo systemctl enable --now fail2ban && sudo fail2ban-client status sshd
```

- **before:** 6× login salah → tidak ada blokir
- **after:** 6× login salah → IP masuk `Banned IP list`; `hydra` berhenti karena ditolak
- **bukti:** `A4_before_no_ban.txt`, `A4_after_client_status.png`, `A4_after_hydra_blocked.txt`
- **jebakan:** `ignoreip` wajib memuat IP monitoring `.200` dan host NAT `10.0.3.2`, kalau tidak Blue Team ikut ter-ban.

B-1 · Minimalisasi service/port *(Tahap 1)*

```
sudo systemctl disable --now avahi-daemon cups cups-browsed rpcbind ModemManager 2>/dev/null
ss -tulpn | grep LISTEN
sudo ufw status numbered          # pastikan hanya 22/2222, 8080, 1883, (5432 lokal)
```

- **before/after:** `nmap -sS -p- 192.168.4.5` dari Kali, dua file
- **bukti:** `B1_before_nmap_full.txt`, `B1_after_nmap_full.txt`, `B1_port_delta.md` (isi: port hilang + alasan)
- **jebakan:** jangan matikan `postgresql`/`thingsboard`; `ModemManager` aman dimatikan.

B-2 · Firewall whitelist + PostgreSQL lokal *(Tahap 1)*

```
sudo ufw default deny incoming && sudo ufw default allow outgoing
sudo ufw allow 2222/tcp
sudo ufw allow from 192.168.4.0/24 to any port 8080 proto tcp
sudo ufw allow from 192.168.4.100 to any port 1883 proto tcp
sudo ufw allow from 192.168.4.200 to any port 514 proto udp
sudo ufw --force enable && sudo ufw status verbose
```

```
sudo sed -i "s/^#\?listen_addresses.*/listen_addresses = '127.0.0.1'/" /etc/postgresql/*/main/postgresql.conf
sudo systemctl restart postgresql
```

- **lulus bila:** dari Kali hanya 2222/8080/1883 `open`, sisanya `filtered`; `psql -h 192.168.4.5 -U thingsboard` → timeout; **dan** dashboard tetap `200`
- **bukti:** `B2_before_nmap.txt`, `B2_after_ufw_status.png`, `B2_after_nmap_filtered.png`, `B2_after_web_200.txt`
- **jebakan:** aktifkan `ufw` **setelah** aturan SSH dibuat. Urutan salah = terkunci di luar server.

B-3 · Patch OS + hapus kredensial default *(patch: Tahap 1 · akun default: Tahap 2)*

```
sudo apt update && sudo apt -y full-upgrade
sudo apt install -y unattended-upgrades && sudo dpkg-reconfigure -plow unattended-upgrades
apt list --upgradable          # sisa paket phased update dicatat, bukan diklaim kosong

# Tahap 2: akun default ThingsBoard
# UI: login sysadmin@thingsboard.org / sysadmin -> ganti password -> buat akun baru -> hapus default
```

- **bukti:** `B3_before_apt_upgradable.txt`, `B3_after_apt_upgraded.txt`, `B3_after_default_admin_rejected.txt`
- **jebakan:** jangan klaim "upgradable kosong" bila masih ada 15 paket phased — tulis apa adanya.

C-1 · Rahasia tidak hardcoded / tidak masuk repo *(Tahap 1)*

```
sudo chmod 600 /etc/thingsboard/conf/thingsboard.conf
sudo chown thingsboard:thingsboard /etc/thingsboard/conf/thingsboard.conf
grep -rnE '(password|token|secret)\s*=\s*\S{6,}' --include=*.md --include=*.sh . | grep -v '<'
```

- **bukti:** `C1_before_secret_in_repo.txt` (temuan), `C1_after_conf_chmod600.txt`, `C1_after_grep_clean.txt`

C-2 · Rotasi token + validasi telemetri + TLS MQTT *(Tahap 2)*

```
# 1. rotasi token: UI Devices -> KABITA-Timbangan-01 -> Manage credentials -> rotate
# 2. rule chain "KABITA-Validate": tolak berat_kg <5 atau >120, pakan_kg <0 atau >10
# 3. TLS MQTT (paling berat — butuh keystore)
sudo keytool -genkeypair -alias mqttserver -keyalg RSA -keysize 2048 -validity 3650 \
  -dname "CN=192.168.4.5" -keystore /etc/thingsboard/conf/keystore.jks \
  -storepass <REDACTED> -keypass <REDACTED>
sudo sed -i 's/^#\?export MQTT_SSL_ENABLED.*/export MQTT_SSL_ENABLED=true/'
/etc/thingsboard/conf/thingsboard.conf
sudo sed -i 's/^#\?export MQTT_BIND_PORT.*/export MQTT_BIND_PORT=8883/' /etc/thingsboard/conf/thingsboard.conf
sudo systemctl restart thingsboard
```

- **lulus bila:** token lama → `401` / `not authorized`; `{"berat_kg":99.9}` ditolak rule chain; publish tanpa TLS ke 8883 gagal
- **bukti:** `C2_before_telemetry_injection.txt`, `C2_after_token_rotated_401.txt`, `C2_after_range_rejected.txt`, `C2_after_mqtt_tls.txt`
- **jebakan:** kalau TLS kehabisan waktu, jangan diam-diam melewatinya — catat sebagai `TERBUKA` di `purple-team-log.md` (ini justru temuan yang jujur).

C-3 · Least privilege PostgreSQL + logging ke sensor *(Tahap 1)*

```
sudo -u postgres psql -c "ALTER ROLE thingsboard NOSUPERUSER NOCREATEDB NOCREATEROLE;"
sudo -u postgres psql -c "\du thingsboard"
echo '*.* @@192.168.4.200:514' | sudo tee /etc/rsyslog.d/50-remote.conf
sudo systemctl restart rsyslog && sudo grep -c "Failed password" /var/log/auth.log
```

- **lulus bila:** `thingsboard` bukan superuser; log Red Team muncul di Security Onion
- **bukti:** `C3_after_pg_roles.txt`, `C3_after_authlog_failed_logins.txt`, `C3_after_logs_in_onion.png`

---

3. Alokasi waktu realistis

Sesi	Isi	Estimasi
Sesi 0	Prasyarat: ThingsBoard hidup, snapshot, SSH key, baseline baru	60–90 menit (unduh paket bisa lama)

Sesi 1	A-1, A-3, A-4, B-1, B-2, B-3(patch), C-1, C-3 + sebelum/sesudah `nmap`	90 menit
Sesi 2	Serangan baseline RT-01/RT-02/RT-03/RT-04 (rekam `before`)	120 menit
Sesi 3	Tahap 2: B-3(akun), A-2, C-2 lalu uji ulang semua skenario (rekam `after`)	90 menit
Sesi 4	Isi `purple-team-log.md` + Vulnerability Assessment Report	60 menit

---

4. Checklist cepat (centang saat benar-benar selesai)

- [ ] Baseline baru ThingsBoard terekam (pcap + metrik)
- [ ] A-1 root login ditolak — bukti ada
- [ ] A-2 login password ditolak, key masuk — bukti ada
- [ ] A-3 SSH di 2222, 22 tertutup — bukti ada
- [ ] A-4 fail2ban mem-ban setelah 5 gagal — bukti ada
- [ ] B-1 port berkurang + delta dijelaskan
- [ ] B-2 `nmap` filtered + dashboard tetap 200
- [ ] B-3 patch dicatat apa adanya + akun default ditolak
- [ ] C-1 tidak ada rahasia di repo
- [ ] C-2 token lama 401 + nilai ekstrem ditolak
- [ ] C-3 role PostgreSQL non-superuser + log masuk Onion
- [ ] Setiap baris di atas punya file bukti di `docs/blueteam/evidence/`

---

5. Jebakan yang paling sering menghabiskan waktu

1. **Lockout SSH** — A-2/A-3/ufw dijalankan sebelum key/aturan baru diuji. Selalu buka sesi kedua sebelum menutup yang pertama, dan pastikan konsol VirtualBox bisa dipakai.
2. **fail2ban mem-ban Blue Team** — lupa `ignoreip` untuk `.200` dan host NAT.
3. **ufw memblokir 8080** → dashboard "mati" padahal ThingsBoard sehat; cek `ufw status` dulu sebelum menyalahkan aplikasi.
4. **Mengklaim "selesai" tanpa file** — dosen membuka repo, bukan laptop. Tanpa bukti = status tetap `Sebagian`.
5. **Menjalankan hardening penutup sebelum serangan** → bukti `before` palsu, nilai Purple Team Loop hilang.